

TP 1.4 : Scan et analyse de sécurité d'un système Windows

1. Introduction et Objectifs

L'objectif de ce TP est de simuler une phase de reconnaissance sur une machine cible Windows (IP : 192.168.56.20) afin d'identifier les services exposés, d'analyser leur configuration et d'évaluer les risques de sécurité associés pour une entreprise.

2. Préparation de la Cible

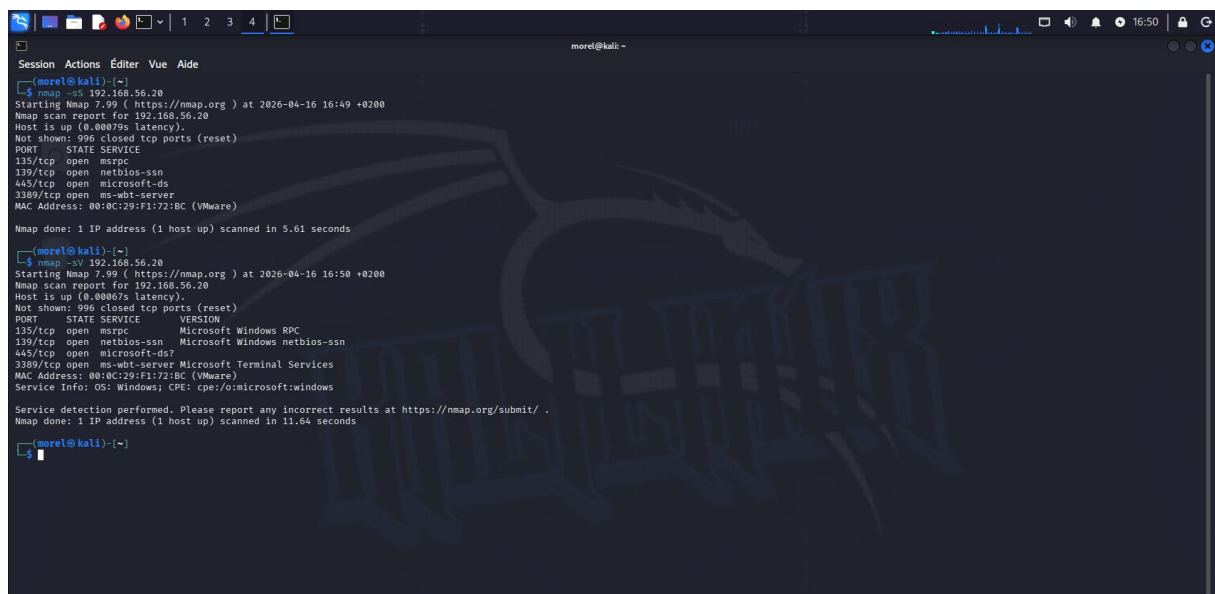
Avant l'audit, les actions suivantes ont été réalisées sur la machine Windows :

Identification IP : 192.168.56.20 via la commande ipconfig.

Test de connectivité : Réussite du Ping depuis la machine Kali Linux.

Altération de la sécurité : Désactivation du pare-feu Windows pour observer les services sans filtrage, simulant ainsi une machine mal configurée.

3. Scan des ports Windows et identifications des services



```
morel@kali:~$ nmap -sS 192.168.56.20
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-16 16:49 +0200
Nmap scan report for 192.168.56.20
Host is up (0.00079s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
3389/tcp   open  ms-wbt-server
MAC Address: 00:0C:29:F1:72:BC (VMware)

Nmap done: 1 IP address (1 host up) scanned in 5.61 seconds

morel@kali:~$ nmap -sV 192.168.56.20
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-16 16:50 +0200
Nmap scan report for 192.168.56.20
Host is up (0.00067s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE          VERSION
135/tcp    open  msrpc            Microsoft Windows RPC
139/tcp    open  netbios-ssn      Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds?    Microsoft Windows [unidentified]
3389/tcp   open  ms-wbt-server     Microsoft Windows [unidentified]
MAC Address: 00:0C:29:F1:72:BC (VMware)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.64 seconds
```

- Détection des ports ouverts

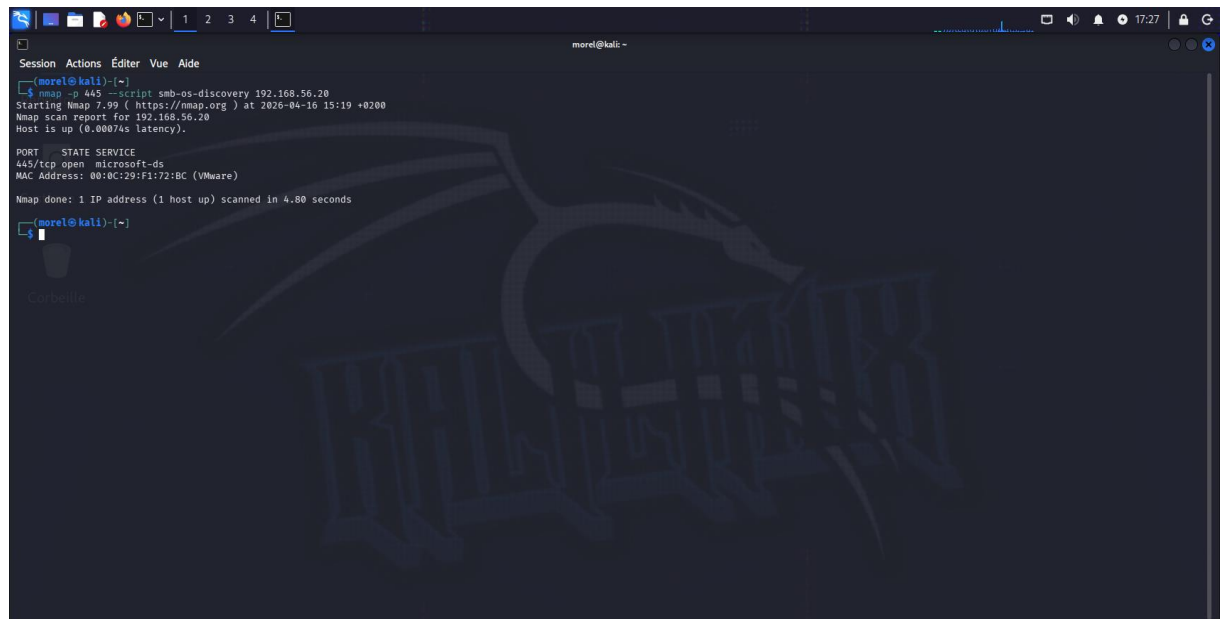
La commande `nmap -sV 192.168.56.20` a permis d'identifier les ports critiques suivants :

Port 445 (TCP) : Service microsoft-ds (SMB). Utilisé pour le partage de fichiers.

Port 135/139 (TCP) : Services NetBIOS et RPC.

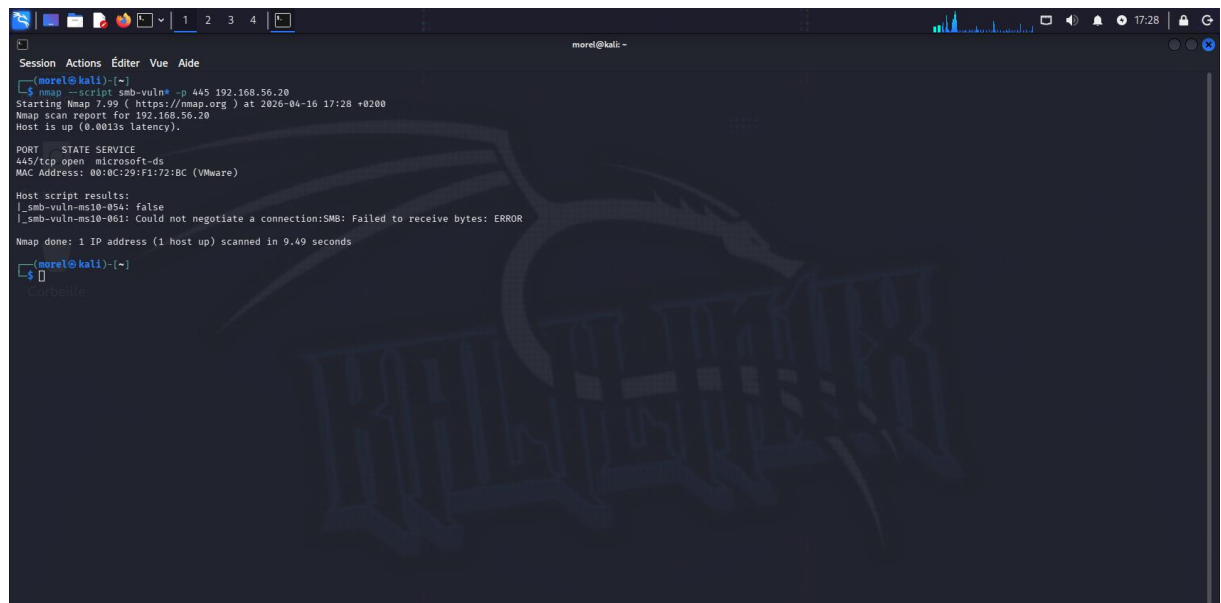
Port 3389 (TCP) : Service RDP (Remote Desktop), activé manuellement durant le TP.

4. Utilisation des script Nmap pour Windows



```
morel@kali: ~  
$ nmap -p 445 --script smb-os-discovery 192.168.56.20  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-16 15:19 +0200  
Nmap scan report for 192.168.56.20  
Host is up (0.00074s latency).  
  
PORT      STATE SERVICE  
445/tcp   open  microsoft-ds  
MAC Address: 00:0C:29:F1:72:BC (VMware)  
  
Nmap done: 1 IP address (1 host up) scanned in 4.80 seconds  
  
morel@kali: ~  
$
```

5. Détection des vulnérabilité SMB



```
morel@kali: ~  
$ nmap --script smb-vuln -p 445 192.168.56.20  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-16 17:28 +0200  
Nmap scan report for 192.168.56.20  
Host is up (0.0013s latency).  
  
PORT      STATE SERVICE  
445/tcp   open  microsoft-ds  
MAC Address: 00:0C:29:F1:72:BC (VMware)  
  
Host script results:  
_smb-vuln-ms10-054: false  
_smb-vuln-ms10-061: Could not negotiate a connection:SMB: Failed to receive bytes: ERROR  
  
Nmap done: 1 IP address (1 host up) scanned in 9.49 seconds  
  
morel@kali: ~  
$
```

6. Analyse des services RDP

```
morel@kali:~$ nmap -p 3389 --script rdp-enum-encryption 192.168.56.20
Starting Nmap 7.99 ( https://nmap.org ) at 2020-04-16 17:29 +0200
Nmap scan report for 192.168.56.20
Host is up (0.0012s latency).

PORT      STATE SERVICE
3389/tcp  open  ms-wbt-server
| rdp-enum-encryption:
|   Security layer
|   | CredSSP (NLA): SUCCESS
|   | CredSSP with Early User Auth: SUCCESS
|   | RDPSTLS: SUCCESS
| MAC Address: 00:0C:29:F1:72:BC (VMware)
Nmap done: 1 IP address (1 host up) scanned in 5.77 seconds

morel@kali:~$
```

7. Analyse Globale de la Sécurité

- Identification des Risques

Exploitation à distance : Le service SMB (445) est le vecteur principal des Ransomwares. S'il est exposé sans mise à jour, l'intégralité du système peut être chiffrée.

Prise de contrôle : Le service RDP (3389) expose la machine à des attaques par force brute. Un attaquant peut tenter de deviner les identifiants pour ouvrir une session interactive.

- Mesures de Sécurisation

Service	Mesure de sécurité
General	Réactiver le Pare-feu Windows pour filtrer les flux entrants.
SMB	Désactiver définitivement SMBv1 et n'utiliser que SMBv2/v3 chiffré.
RDP	Limiter l'accès aux seules adresses IP autorisées et activer l'authentification

8. Conclusion

Ce TP démontre qu'une simple erreur de configuration (pare-feu désactivé) rend une machine immédiatement vulnérable à l'énumération de services. L'audit a permis de mettre en évidence que la sécurité repose sur une défense en profondeur : le filtrage réseau (pare-feu) couplé à la mise à jour des protocoles (désactivation de SMBv1).